

Experiment No. 3

Aim:

Study of SAST tools (Open Source like GitHub, GitLab and so on).

Theory:

Source Code Analysis Tools, which includes a list of those that are “Open Source or Free Tools of This Type”. Any such tools could certainly be used. One such cloud service is:

- **GitHub** code scanning - A free for open-source static analysis service that uses GitHub Actions and CodeQL to scan public repositories on GitHub. Supports C/C++, C#, Ruby (beta), Java, JavaScript/TypeScript, Python, and Go (see here for more information)

- o If you do not want to use GitHub Actions, you may use the CodeQL CLI; however, be sure to read the license terms in full.

- o By default, CodeQL only looks for high fidelity security related results (well-known true positives), so your results may look different from LGTM.

- o To achieve the same or similar results provided by LGTM, try enabling the security-and-quality query suite within the CodeQL query pack.

In addition, we are aware of the following commercial SAST tools that are free for Open-Source projects:

- Contrast CodeSec - Scan & Serverless - Web App and API code scanners via command line or through GitHub actions. CodeSec - Scan supports Java, JavaScript and .NET, while CodeSec - Serverless supports AWS Lambda Functions (Java + Python). These tools are actually free for all projects, not just open source.

- Coverity Scan Static Analysis - Can be lashed into Travis-CI so it's done automatically with online resources. Supports over a dozen programming languages.

- HCL AppScan CodeSweep - This is a SAST community edition version of HCL AppScan. Free for everyone to use. The tool currently supports Python, Ruby, JS (Vue, Node, Angular, JQuery, React, etc), PHP, Perl, Go, TypeScript & more, with new languages being added frequently.

- o CodeSweep - VS Code Plugin - Scans files upon saving them. The results show the location of a finding, type, and remediation advice. Auto-fix available with free trial or subscription.

- o CodeSweep - JetBrains Plugin - Scans files upon saving them. The results show the location of a finding, type, and remediation advice. Auto-fix available with free trial or subscription.

- o CodeSweep - GitHub Action - Scan the new code on a push/pull request using a GitHub action. Findings are highlighted in the Files Changed view and details about the issue and mitigation steps can be found in the Actions page. Unrestricted usage allowed with a free trial account.

- AppSweep - a free for everyone mobile application security testing tool for Android. It analyzes the compiled application and does not require access to the source code. The tool performs security assessment not only of the executable code but also of application resources and configuration file. Integration into CI/CD is supported.

Source Code Analysis Tools | Dn... | GitHub Pricing, Alternatives & M... | +

captera.com/129657/GitHub/

Software Categories | Service Categories | Guides & Research | Who We Are | For Vendors | Write a Review

Static Application Security Testing (SAST) Software | Free Static Application Security Testing (SAST) Software | GitHub



GitHub

by GitHub

4.8 (5087)

Write a Review!

SAVE

Feedback

ABOUT | PRICING | FEATURES | COMPARE ALTERNATIVES | REVIEWS | Q&A | RESOURCES

SHARE

PRICE

VIEW ALL

Starting From

Not provided by vendor

Yes, has free trial

Yes, has free version

Pricing Model:

Per User

REVIEWS

VIEW ALL

4.8 Overall

4.8 (5087)

Ease of Use

Customer Service

4.4

4.4

TOP FEATURES

VIEW ALL

Vulnerability Scanning

For Developers

Application Security

Version Control

5.0

4.9

4.8

4.8

Type here to search

12:02 PM 8/29/2022

```
admin2@breachlock:~$ git clone https://github.com/CoolerVoid/codewarrior
Cloning into 'codewarrior'...
remote: Enumerating objects: 459, done.
remote: Total 459 (delta 0), reused 0 (delta 0), pack-reused 459
Receiving objects: 100% (459/459), 2.71 MiB | 714.00 KiB/s, done.
Resolving deltas: 100% (156/156), done.
Checking connectivity... done.
```

378 lines (325 clon) 15.2 KB

Run

Share

```
1 <!DOCTYPE html>
2 <html lang="en">
3
4 <head>
5 <title>The Sports Foundation</title>
6 <meta charset="utf-8">
7 <meta name="viewport" content="width=device-width, initial-scale=1, shrink-to-fit=no">
8
9 <link href="https://fonts.googleapis.com/css?family=Roboto:300,400,500,700,900" rel="stylesheet">
10
11
12 <link rel="stylesheet" href="fonts/icomoon/style.css">
13
14 <link rel="stylesheet" href="css/bootstrap.min.css">
15 <link rel="stylesheet" href="css/magnific-popup.css">
16 <link rel="stylesheet" href="css/jquery-ui.css">
17 <link rel="stylesheet" href="css/owl.carousel.min.css">
18 <link rel="stylesheet" href="css/owl.theme.default.min.css">
19
20 <link rel="stylesheet" href="css/bootstrap-datepicker.css">
21
22 <link rel="stylesheet" href="fonts/Flaticon/font/Flaticon.css">
23
24 <link rel="stylesheet" href="css/aos.css">
25
26 <link rel="stylesheet" href="css/style.css">
27
28 </head>
29
30 <body data-spy="scroll" data-target="#site-navbar-target" data-offset="300">
31
32 <div class="site-wrap" id="home-section">
```

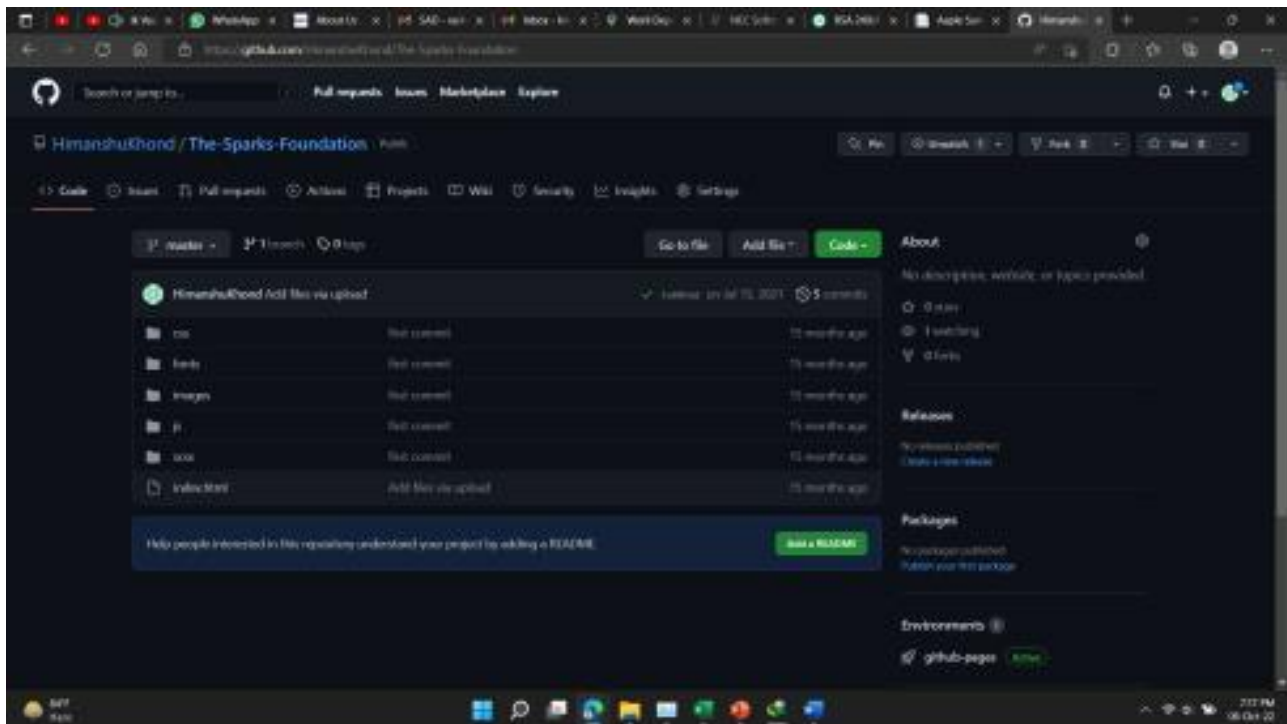
GitLab:

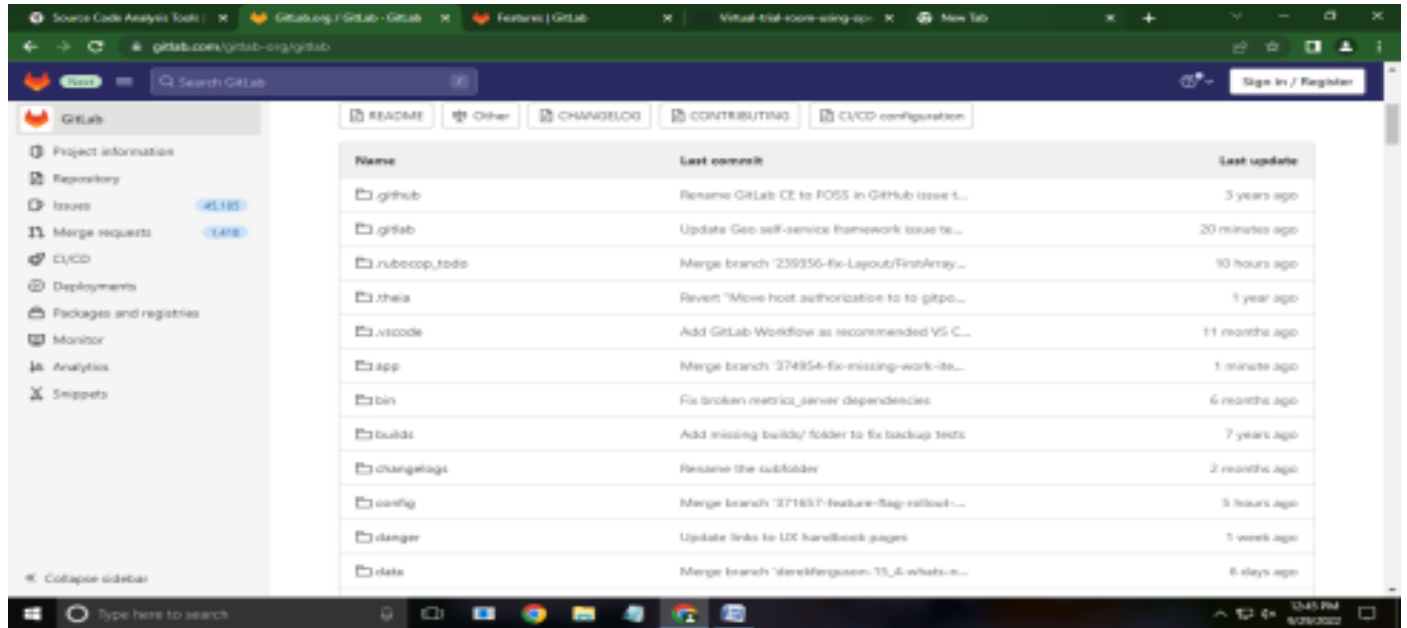
GitLab is a complete DevOps platform, delivered as a single application, fundamentally changing the way Development, Security, and Ops teams collaborate. GitLab helps teams accelerate software delivery from weeks to minutes, reduce development costs, and reduce the risk of application vulnerabilities while increasing developer productivity.

GitLab is the best Cloud-based DevOps platform that helps small to large enterprises improve business operations using time tracking, incident management, code review, regulatory compliance, and more.

GitLab Features:

- Application Security
- Source-Code Scanning
- Testing Management
- Vulnerability Scanning
- For Developers
- Source Control
- Approval Process Control
- Continuous Delivery
- Deployment Management
- Workflow Management
- Access Controls/Permissions
- Automated Testing
- Collaboration Tools
- Continuous Deployment
- Continuous Integration





Conclusion:

Hence, we have studied SAST tools (Open Source like GitHub, GitLab and so on).